国密 PDF 数字签名

技术标准验证报告

GB/T 35275-2017（CMS 分离签名） · GB/T 38540-2020（SES 电子签章）

验证对象：GBT35275-2017.pdf / GBT38540-2020.pdf
验证日期：2026-09-17（含证书链深度验证）

结论：两份样本均符合对应国家标准，全部验证项通过
证书链、CRL、OCSP 全部内嵌于 PDF，离线可完整验证

一、结论摘要

样本	签名格式	签名证书	摘要一致性	密码学验签	时间戳	证书链	LTV/DSS	判定
35275-2017	/GM.sm2cms.detached	113548382 SM2	☐	☐ SM3(ZA‖M)	☐ RFC3161	☐ 终端→CA→根	☐ DSS=92	符合
38540-2020	/GM.sm2seal	113548382 SM2	☐	☐ 双签名	☐ 字段4	☐ 终端→CA→根	☐ DSS=92	符合

汇总计数：35275 样本 pdfsig_verify 15/15、verify_gm_pdf 14/14；38540 样本 pdfsig_verify 22/22；两样本证书链深度验证全部通过。

二、依据标准（引用）

标准/规范	名称	在本验证中的作用
GB/T 35275-2017	SM2密码算法加密签名消息语法规范	CMS 分离签名与 /GM.sm2cms.detached 语义
GB/T 38540-2020	安全电子签章密码技术规范	电子印章 SES（SES_Signature/SESeal）结构与 /GM.sm2seal 语义
GB/T 32918.2-2016	SM2椭圆曲线公钥密码算法 第2部分：数字签名算法	SM2 验签、ZA 计算、素域曲线参数
GB/T 32905-2016	SM3密码杂凑算法	消息摘要与 ZA 计算底层
RFC 5652	Cryptographic Message Syntax (CMS)	SignedData/SignerInfo/signedAttrs 的 DER 编码规则
ISO 32000-1:2008	PDF 文档管理	数字签名 §12.8、ByteRange、DSS（§12.8.4，LTV）
RFC 3161	Time-Stamp Protocol	时间戳令牌结构与 TSTInfo 语义
RFC 6960	OCSP 协议	响应结构（responseStatus=ENUMERATED）、CertID/吊销状态语义

三、逐项验证结果

3.1 GB/T 35275-2017 样本（/GM.sm2cms.detached）

#	验证项	证据
1	PDF 可打开	页数=1
2	存在签名域	签名对象 xref=[75]
3	签名过滤器	Filter=/Adobe.SM2 SubFilter=/GM.sm2cms.detached
4	ByteRange 结构	[0, 54275, 198619, 30870]（4 段标准结构）
5	签名内容存在	Contents 长度=72171 字节（DER 二进制）
6	ByteRange 分段可读	覆盖字节=85145
7	CMS 结构解析	contentType=1.2.840.113549.1.7.2，证书数=3，签名者数=1
8	签名证书匹配	C=CN, O=ChinalTboys, OU=Person, CN=2829969554@qq.com
9	签名算法	SM3-SM2（1.2.156.10197.1.501），摘要 SM3（1.2.156.10197.1.401）
10	messageDigest 一致性	声明=99f29c0b…，计算=99f29c0b…（ByteRange 双段 SM3）
11	SM2 签名验签(signedAttrs)	SET 最小长度 DER 编码，e=SM3(ZA‖M)，验签通过
12	时间戳令牌（RFC3161）	证书数=2；TSA SM3-SM2；policy=1.3.6.1.4.1.4146.1.95；genTime=20260916141445Z
13	证书链	终端 → CN=SM2CA → CN=ROOTCA
14	LTV/DSS 对象	DSS 对象=92（pikepdf 按 Type=/DSS 精确定位）
15	DSS 验证材料	Certs=3、CRLs=2、OCSPs=3

汇总：15/15 项通过（verify_gm_pdf 结构检查另计 14/14 项通过）。

3.2 GB/T 38540-2020 样本（/GM.sm2seal）

#	验证项	证据
1	PDF 可打开	页数=1
2	存在签名域	签名对象 xref=[75]
3	签名过滤器	Filter=/Adobe.SM2 SubFilter=/GM.sm2seal
4	ByteRange 结构	[0, 54267, 198611, 30868]
5	签名内容存在	Contents 长度=72171 字节
6	ByteRange 分段可读	覆盖字节=85135
7	SES 结构解析	顶层子元素=5（SES_Signature 标准五字段）
8-12	SES 字段类型	toSign=0x30/20143B；印章图像=0x04/1677B；摘要算法=0x06/8B；签名值=0x03/71B；时间戳=0xA0/2278B
13	SES_ToSign 解析	version=4；esInfo=20070B；时间=20260916144120Z；签名值=32B；类型=PDF-SM2-SEAL
14	印章信息解析	SESealInfo=18305B；图片=1677B(PNG)；摘要算法OID=1.2.156.10197.1.501；印章签名=71B
15	印章 ID	caa36f4f-0db5-445e-b255-67eaa0acd83c
16	印章证书提取	证书数=3：终端 → CN=SM2CA → CN=ROOTCA
17	印章签名验签(SESealInfo)	证书113548382 对 SESealInfo 完整 DER 验签通过，e=SM3(ZA‖M)
18	文档签名验签(SES_ToSign)	证书113548382 对 SES_ToSign 完整 DER 验签通过，e=SM3(ZA‖M)
19	时间戳令牌验证	证书数=2；TSA 含时间戳(1.3.6.1.5.5.7.3.8) EKU；TSA 令牌 SM2 验签通过
20	证书链	终端 → CN=SM2CA → CN=ROOTCA
21	LTV/DSS 对象	DSS 对象=92（pikepdf 按 Type=/DSS 精确定位）
22	DSS 验证材料	Certs=3、CRLs=2、OCSPs=3

汇总：22/22 项通过。

3.3 证书链深度验证（离线材料盘点，两样本同批）

针对"签名结构是否真的包含证书链、离线能否验证"，对签名 Contents 与 DSS 对象做全量提取与逐级密码学验签。

序列号	证书	算法	嵌入位置
113548382	签名者 C=CN, O=ChinalTboys, OU=Person, CN=2829969554@qq.com	SM2(EC256)	签名 Contents
1cdd33203a2ce	CA 证书 CN=SM2CA	SM2(EC256)	签名 Contents
13fbe86586d3f90	根证书 C=CN, O=My Org, CN=ROOTCA	RSA 2048	签名 Contents
11355e5c4	TSA 签名证书 CN=SM2ROOTCA By Timstamp SM3	SM2(EC256)	时间戳令牌
13fbe865870f9b4	TSA 根证书 C=CN, O=My Org, CN=SM2ROOTCA	SM2(EC256)	时间戳令牌

文档签名链（子证书 ← 父证书公钥，逐级验签）

签名者 113548382 ← SM2CA 1cdd33203a2ce SM2(ZA) 验签通过
SM2CA 1cdd33203a2ce ← ROOTCA 13fbe86586d3f90 RSA-sha256 验签通过
ROOTCA 13fbe86586d3f90 自签名（信任锚） RSA-sha256 验签通过

TSA 时间戳链（逐级验签）

TSA 签名证书 11355e5c4 ← SM2ROOTCA 13fbe865870f9b4 SM2(ZA) 验签通过
SM2ROOTCA 13fbe865870f9b4 自签名（信任锚） SM2(ZA) 验签通过

吊销证据（DSS 对象内，全部离线可核验）

材料	数量	内容
CRL	2	CRL[0] 签发者=SM2CA（SM2(ZA) 验签通过，吊销 0 条）；CRL[1] 签发者=ROOTCA（RSA-sha256 验签通过，吊销 0 条）
OCSP	3	OCSP[0]→113548382、OCSP[1]→1cdd33203a2ce、OCSP[2]→13fbe86586d3f90，状态全部正常(good)

结论：证书链、CRL、OCSP 全部内嵌于 PDF（签名 Contents + DSS），离线即可完成每一级的密码学验签与吊销状态核对，不依赖任何外部 URL。

四、验证方法与程序

4.1 技术路线

A 线 —— 纯标准库自实现（不信任任何现成验签实现）：

① SM3（sm2lib.py）：按 GB/T 32905-2016 实现，标准测试向量自检通过。

② SM2 验签（sm2lib.py）：按 GB/T 32918.2-2016 —— Fp 曲线参数、点加/倍点/标量乘、ZA=SM3(ENTL‖ID‖a‖b‖xG‖yG‖xA‖yA)（默认 ID 1234567812345678）、R=(e·G+r·Q) 判等。

③ RSA 验签（pdfsig_verify.py）：PKCS#1 v1.5 —— 验 00 01 填充头、定位 00 分隔符、解析 DigestInfo 比对。

④ DER 解析（derlib.py）：X.690 TLV；X.509 证书（序列号/DN/公钥/SKI/AKI/EKU/策略/基本约束）、CMS SignedData/SignerInfo。

⑤ 签名域提取（pdfsig_verify.py + PyMuPDF）：ByteRange 双段拼接 SM3 与 messageDigest 比对。

⑥ 签名对象重建：CMS=signedAttrs 的 SET 最小长度 DER；SES=印章对 SESealInfo、文档对 SES_ToSign 完整 SEQUENCE DER；均 e=SM3(ZA‖M)。

⑦ 时间戳令牌（RFC 3161）：TimeStampToken→CMS→TSTInfo→TSA 证书匹配→SM2 验签。

B 线 —— 第三方库交叉验证：⑧ verify_gm_pdf.py（pikepdf/cryptography/asn1crypto）做结构深度检查，SM2 验签回落 A 线；⑨ DSS 定位用 pikepdf 按 Type=/DSS 精确扫描（避免 PyMuPDF 误把 Catalog 的 /DSS 引用当 DSS 对象），数组元素为流对象直接取 DER。

4.2 程序清单（位于 GMcheck\）

文件	作用
pdfsig_verify.py	主验证：全项检查、时间戳令牌、SES 深度验签、RSA PKCS#1 v1.5、DSS 材料检查
verify_gm_pdf.py	pikepdf/cryptography/asn1crypto 交叉验证（CMS 深度检查，SES 走跳过分支）
chain_deep_verify.py	证书链深度验证：全量提取、AKI/SKI+DN 构链、逐级验签、CRL/OCSP 核验、离线结论
derlib.py	DER TLV、X.509、CMS、SES 辅助解析
sm2lib.py	SM3、SM2 曲线、ZA、sm2_verify
check.cmd	一键三步验证（结构→全项→深度链），英文输出规避 Win11 GBK 中文乱码

4.3 运行方式

```
check.cmd
:: 等价手工步骤：
python verify_gm_pdf.py GBT35275-2017.pdf
python verify_gm_pdf.py GBT38540-2020.pdf
python pdfsig_verify.py "GBT35275-2017.pdf" "GBT38540-2020.pdf"
python chain_deep_verify.py "GBT35275-2017.pdf" "GBT38540-2020.pdf"
```

五、关键验证事实与实现要点

1. 签名对象编码：35275 的 CMS 签名对象为 signedAttrs 集合的 DER 编码——首字节 0x31（SET）+ DER 最小长度（22558 字节用 0x82 两字节长格式），直接决定摘要一致性。

2. ZA 参与：两样本均采用含 ZA 的摘要模式（e=SM3(ZA‖M)），符合 GB/T 32918.2-2016；无 ZA 简模式验签失败，反向证明符合标准。

3. SES 双签名：38540 含印章签名（SESealInfo）与文档签名（SES_ToSign）两层，均验签通过。

4. 时间戳：两样本均嵌入 SM3-SM2 时间戳令牌，policy=1.3.6.1.4.1.4146.1.95；TSA 令牌验签通过，TSA 链（TSA→SM2ROOTCA）独立验签通过。

5. 证书链：文档链 113548382 → 1cdd33203a2ce → 13fbe86586d3f90，与 AKI/SKI 一致，逐级验签全部通过（含根自签 RSA）。

6. 吊销证据离线可用：DSS(xref=92) 内含 Certs=3、CRLs=2、OCSPs=3；CRL 由 SM2CA 与 ROOTCA 分别签发并验签通过；OCSP 对链上全部证书返回正常(good)。

7. 材料全部内嵌：验证不访问任何外部 URL，仅凭 PDF 即可完成证书链验证与吊销状态核对，满足 LTV 离线可用性。

六、局限性与说明

1. 验证聚焦签名密码学正确性 + 结构符合性 + 链与吊销证据完整性，未对字体嵌入、元数据、页面内容做文档一致性检查（不属于签名标准范畴）。

2. genTime 为 UTC（20260916141445Z），PDF M 条目为本地时区（D:20260916221444+08'00'），相差 8 小时属同一时刻的时区表示，符合规范。

3. 所有结论基于对样本二进制内容的独立解析与重算，未借助商业验签工具；如需权威交叉验证可选用符合 GB/T 标准实现的 SDK。

4. verify_gm_pdf.py 对 38540（SES）按设计走"结构检查 + 提示专用验证"分支，密码学验证由 pdfsig_verify 与 chain_deep_verify 覆盖。

MODPKICA 国密 PDF 签名验证工具链（纯 Python，GMcheck\ 三步验证） · 完